

Nathaniel Abera

August 6, 2026

Managing Information Security

A. The company in this case study is Stellar Financial Solutions. This is a private financial institution that is based in San Francisco but has offices in the European Union as well. The first deficiency within the company's security management program is that they are missing a formal training program that is based on security awareness for its employees. None of the employees are trained to be aware of any incidents that may occur. Based on the first incident report, the attacker was able to infiltrate the company by impersonating the HR department through a phishing email, and the main reason this was able to happen was because they weren't able to train their employees to identify suspicious activity such as phishing emails. The company's current security management program lacks this vital implementation and currently only relies on an open document library as well as emails of links to resources that happen every quarter. There is no measurement of training performance, and this lack overall puts the company's employees at risk of being victims of phishing attacks. Preparing employees to recognize phishing attempts through required measured training will address this deficiency.

The second deficiency within Stellar Financial Solutions' security management program is the lack of implementing a patch management system that can detect any missing patches in operating systems such as Windows and patch them before becoming victims of exploitation techniques. As stated within the case study, Stellar Financial Solutions had become a victim of a Windows patch exploitation because they weren't able to update their system in time, and it led to their credit services suffering from a critical ransomware attack that led the department to be inoperable for more than 2 weeks. Currently, the company does have a scanning tool that performs scans to detect these kinds of things, but the issue is that this only occurs once a month and isn't a constant monitoring system. If they were able to implement a patch management program that was continuously monitoring this system and coordinating alerts to the correct dedicated team, they would be able to address this weakness and prevent exposed vulnerabilities from being exploited.

A1. The first change I would like to recommend to Stellar Financial Solutions is regarding the lack of security awareness training for its employees. This should be mandatory training within the security management program, as it requires all employees to complete this training every

year and become aware of unusual security activity. Employees that are in high-risk roles will also be assigned additional training to further educate them on security awareness. This training will also be measured and reported to roles of leadership to see how employees are responding to the training, and it helps decide whether they understand the concept or are lacking in some areas (Wilson & Hash, 2003). Once this implementation is made, it will prevent the occurrence of incidents similar to the phishing attack, which had succeeded because employees weren't able to recognize suspicious activity within their email inbox. An employee that completes this training will be able to identify phishing emails and fake credential stealing websites and will be knowledgeable as to what they need to do to report these attacks.

The second change I would recommend to Stellar Financial Solutions is regarding the phishing simulations being added within the security management program. The company would send simulated phishing attempts to employees via email regularly to track how often employees are actually clicking these emails and submitting credentials. Those who fail will be assigned additional training. This is a great way for employees to practice identifying and responding to phishing emails as it's a safe simulation of real events that may happen. This makes phishing attacks less likely to succeed over time as employees become more aware of them.

The first change I would recommend for the second deficiency is a formal patch management policy. This will shift the current policy to a new standard requiring any vulnerabilities that are identified by scanning tools to be categorized by severity and be given a defined timeframe within a set number of days to have a designated team apply system patches (Souppaya & Scarfone, 2022). As previously noted in the case study, a ransomware attack had succeeded because there was a missing Windows patch, which attackers, had exploited and this had gone unnoticed. Because of this, parts of the company's credit services department were inoperable for more than two weeks. With this policy in place, critical patches would be applied within a required deadline before attackers could exploit them, which would prevent a similar ransomware incident from ever happening in the future.

The second change I would recommend for this deficiency is for the company to add continuous vulnerability monitoring. By adding this, it will be able to alert a dedicated team when suspicious activity is identified rather than relying on the current system where they only do one monthly scan. This new implementation would be continuously monitoring and giving alerts of any suspicious activity or missing critical patches. This change would be able to prevent similar incidents because lateral movement, reconnaissance, and traffic to a malicious domain had all gone undetected before the ransomware attack. By adding this continuous

monitoring, it will give the company early warning signs with triggered alerts that a dedicated team can act on and contain a threat before it spreads.

References

Souppaya, M., & Scarfone, K. (2022). *Guide to enterprise patch management planning: Preventive maintenance for technology* (NIST Special Publication 800-40, Rev. 4). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-40r4>.

Wilson, M., & Hash, J. (2003). *Building an information technology security awareness and training program* (NIST Special Publication 800-50). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-50>